

Relatório de Implementações de Segurança

Versão: 1.0.0

Última Atualização: 04 de maio de 2026

1 Introdução

Este documento detalha as principais implementações de segurança adotadas na API do projeto. Cada medida é descrita com seu propósito, escopo de aplicação e definições técnicas fundamentais.

2 Implementações Detalhadas

2.1 Armazenamento Seguro de Senha

Propósito: Evitar que senhas sejam recuperadas em caso de vazamento do banco de dados, protegendo usuários contra roubo de credenciais.

Escopo: Banco de dados, durante o registro e verificações de login.

Definições Técnicas Fundamentais: Usa BCrypt para transformar senhas em hash irreversível com salt único por usuário, tornando impossível reverter para o texto original

2.2 Proteção contra Ataques de Brute Force

Propósito: Impedir tentativas automatizadas de adivinhar senhas, reduzindo risco de contas comprometidas.

Escopo: Endpoint de autenticação (login) e requisições por IP via Bucket4J.

Definições Técnicas Fundamentais: Limita a 5 tentativas falhas consecutivas por conta (bloqueio de 15 min); Bucket4J bloqueia IPs com muitas requisições suspeitas

2.3 Autenticação via Token

Propósito: Garantir que requisições subsequentes sejam autenticadas sem reenviar senha, com expiração para limitar exposição.

Escopo: Todas as requisições à API após login inicial, no cabeçalho Authorization.

Definições Técnicas Fundamentais: Emite JWT assinado com HMAC256, válido por 2 horas; servidor verifica assinatura e expiração em cada uso

2.4 Autenticação Multifator (MFA)

Propósito: Adicionar camada extra de verificação além da senha, dificultando acesso não autorizado mesmo com credenciais roubadas.

Escopo: Processo de login, após validação inicial de credenciais.

Definições Técnicas Fundamentais: Gera código de uso único enviado por e-mail; acesso só após validação correta do código temporário

2.5 Redefinição e Alteração de Senha

Propósito: Permitir atualização segura de senhas sem expor contas a abusos, verificando titularidade da conta.

Escopo: Fluxos de alteração (usuário logado) e redefinição (sem acesso).

Definições Técnicas Fundamentais: Alteração: válida senha atual; Redefinição: token único por e-mail (expira e inválida após uso), nova senha hasheada com BCrypt

2.6 Logs de Auditoria

Propósito: Rastrear ações para detectar e investigar incidentes, facilitando resposta a ameaças.

Escopo: Eventos de segurança como logins, emissões de tokens, MFA e mudanças de senha.

Definições Técnicas Fundamentais: Registra ID usuário, tipo de evento, IP, data/hora em logs estruturados para monitoramento e análise

2.7 Criptografia de Token

Propósito: Proteger tokens armazenados no app contra extração por malware ou acesso físico ao dispositivo.

Escopo: Armazenamento local no app Android (Jetpack DataStore).

Definições Técnicas Fundamentais: Criptografa com AES/CBC/PKCS7 via Android Keystore (chaves em TEE seguro do SO)

2.8 Criptografia e Comunicação Segura

Propósito: Evitar interceptação de dados sensíveis em trânsito, garantindo confidencialidade e integridade.

Escopo: Toda comunicação cliente-servidor.

Definições Técnicas Fundamentais: HTTPS/TLS obrigatório (rejeita HTTP); certificados digitais, HSTS força conexões seguras para credenciais e tokens